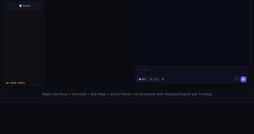
BugBiner AI

Gen AI-Powered Vulnerability Scanner

Professional Bug Bounty & Pentesting Assistant

Application Interface



Core Features

Local AI (Fully Offline)

Runs entirely on your machine with a local LLM — no subscription, no cloud. All data stays private and secure. Supports Ask mode (Q&A) and Agent mode (action execution), vision/image analysis, and one-click vulnerability explanation/fix.

100+ Vulnerability Types

Detects over 100 security bug types — from classic XSS to Business Logic flaws and Race Conditions. Adaptive engine minimizes false positives to near zero.

Burp Suite-Class Tools (Free)

Intruder (both threaded Turbo & Repeater) • Session Handler • Sequencer • WebSocket Scanner • Request Smuggling • Prototype Pollution.

Two-Identity IDOR/BOLA

Detects IDOR/BOLA by comparing responses between two accounts (Victim + Attacker) to conclusively confirm the vulnerability.

Out-of-Band OAST

Integrated with Interactsh to detect blind vulnerabilities (Blind SSRF • Blind OAST • XXE OOB) via external callback.

Site Map (Burp-Style)

URL tree + professional table like Burp Target shows all paths, parameters, MIME types, responses, and discovered vulnerabilities.

AI Assistant — Advanced Features

Ask Mode (Q&A)

Answers any security question with full context (workflows, target, session). Includes conversation history (8 previous turns), image support, Arabic/English language. Supports Markdown formatting.

Agent Mode (Action)

Autonomous agent that executes real commands — curl, nmap, ffuzz, sends HTTP requests, runs custom security tools, and analyzes results. 3 built-in tasks: wake_request, run_python, run_security_test.

AI Vision — Image Analysis

Upload a screenshot — vision model extracts the URL, vulnerability type (OCLN), and precise payload automatically. The Agent then reproduces the payload and tests it against the real target.

Analyze with AI

Analyze with AI button on every Finding — sends full details (URL, Payload, Evidence, Detail) to ai_analyzer.py to classify True Positive vs False Positive with Confidence % and Exploit Impact scoring.

Exploit & Test

Exploit & Test button on every Finding — runs exploit_engine.py to actively test the vulnerability against the live target. Confirms if exploitable and generates a working PoC.

Exploit & Test — Live Verification

Exploit & Test button runs exploit_engine.py to test the vulnerability against the live target. Confirms if exploitable, returns a practical PoC + evidence + auto-generates exploit PoC.

Parallel Operation — No Freezing

Scan and Chat run simultaneously. 24-thread pool for scanning + 1 dedicated browser thread + completely separate Executor. The program never freezes or hangs during scanning; you can browse results and chat with AI at the same time.

Real-Time SSE Streaming

Scan results appear instantly in 4 places simultaneously: Terminal • Live Dashboard • Site Map • Vuln Panel — using Server-Sent Events with zero delay.

Smart Crawler with Real Browser

Uses real Chromium via Puppeteer to browse sites and execute full JavaScript. Discovers all links, forms, API endpoints, even SPAs that traditional crawlers miss.

Secrets & Private Key Detection

Auto-detects AWS keys (AKIA...), Google API, GitHub Tokens, Stripe Live Keys, JWTs, Private Keys (RSA/EC/OPENSSH), Slack Tokens, Twilio, SendGrid in JS files and responses — with Shannon entropy analysis to filter false positives.

Precision Detection — Zero False Positives

Sends a baseline request first to measure normal behavior, then compares the difference precisely: XSS checks literal unencoded reflection, SQLi confirms expression evaluation (number appears, original text disappears), SQLi time-based compares timing against baseline (threshold +4s).

Smart Pause / Resume

Pause the scan at any time and resume automatically. Even if you close the browser or refresh, the state is restored from localStorage and the scan continues from where it stopped without losing progress.

Professional Delivery-Ready Reports

Generates full HTML + JSON reports with Severity (Critical/High/Medium/Low/Info), details, Evidence, and Recommendations — ready for client delivery or Bug Bounty report attachments.

HackerOne Scope Fetcher

Fetches HackerOne program scope automatically (In-scope + Out-of-scope) via 3 methods: __NEXT_DATA__, JSON, data-asset-identifier, and regex patterns. Identifies allowed vulnerability types and available Bounty.

AI Vision — Screenshot Analysis

Supports vision models (Llava, Qwen2-VL) to analyze screenshots and auto-extract URLs, Payloads, and vulnerability type from the image — no manual typing needed.

Project Management + File Browser

Manage projects and files from within the program. Browse any folder on your computer, view file trees, open and edit files, and run AI Tasks on any file directly.

All Supported Vulnerability Types (109+)

Core Adaptive Engine (14 types)

#	Vulnerability	Description	Severity
1	XSS	Reflected Cross-Site Scripting — context-aware reflection analysis (HTML body, attribute, script) • diff confirmation	Critical
2	SQLi	SQL Injection — Boolean-based • Error-based • Time-based (+4s) • UNION • reconfirmation	Critical
3	SQLi (DBMS)	Blind SQLi per DBMS — MySQL, PostgreSQL, MSSQL, Oracle, SQLite (custom payloads)	Critical
4	SSTI	Server-Side Template Injection — Jinja, Freemarker, Velocity — expression evaluation confirmation (1337+1338)	Critical
5	LFI	Local File Inclusion — /etc/passwd, win.ini, proc/self/environ + 6 encodings	High
6	CMDI	Command Injection — ; | && `` $() — blind or timing-based confirmation	Critical
7	SSRF	Server-Side Request Forgery — 169.254.x.x, GCP metadata, Alibaba, localhost	Critical
8	Open Redirect	Redirect to external domain — Location header + netloc analysis	Medium
9	NoSQLi	NoSQL Injection — $ne / $gt operator injection auth bypass	Critical
10	XXE	XML External Entity — file:// + expect:// RCE	Critical
11	CRLF	HTTP Response Splitting — response header injection	High
12	CORS	CORS Misconfiguration — active Origin reflection testing	High
13	Host Header	Host Header Injection — Password reset poisoning • Cache poisoning	High
14	CSRF	Cross-Site Request Forgery — Anti-CSRF token + Origin/Referer check	High

Passive Scanner (5 types)

#	Vulnerability	Description	Severity
15	Secret Exposure	Secrets/keys/tokens in responses — AWS, Google, GitHub, Stripe, Slack, Twilio, Private Keys	Critical
16	CORS (Passive)	ACAO: * + credentials, Origin reflection, null origin	High
17	Cookie Flags	Missing Secure/HttpOnly/SameSite on session cookies	Medium
18	Security Headers	Missing CSP, X-Frame-Options, X-Content-Type-Options, HSTS	Medium
19	Info Disclosure	Version leaks, Stack Traces (PHP/Java/Python/.NET/Ruby), Directory Listing	Low

Extra Detectors (35 types)

#	Vulnerability	Description	Severity
20	SSRF (OOB)	Advanced SSRF with Out-of-Band callback	Critical
21	CMDI (Extra)	Command Injection — additional payloads	Critical
22	SSTI (Extra)	SSTI in XML content	Critical
23	XXE (Extra)	XXE with OOB callback	Critical
24	Open Redirect	Advanced redirect type testing	Medium
25	HPP	HTTP Parameter Pollution — parameter smuggling	Medium
26	LDAPi	LDAP injection — LDAP query injection	Critical
27	XPathi	XPath injection — XPath query injection	High
28	Deserialization	Insecure Deserialization — unsafe unserialize	Critical
29	Type Juggling	PHP Type Juggling — loose comparison bypass	Critical
30	CRLF (Extra)	CRLF injection — additional header injection	High
31	Host Header (Extra)	Host Header Injection — advanced techniques	High
32	Cache Poisoning	Web cache poisoning — cache deception	High
33	Stored XSS	Persistent XSS — two-request scan + display	High
34	Blind XSS	Blind XSS — via OOB callback	High
35	File Upload	File upload bypass — extension/content-type tricks	High
36	Mass Assignment	Mass Assignment / BOPLA — privileged field injection	High
37	Race Condition	Race Condition — concurrent request racing	Critical
38	GraphQL	Introspection • Batching • Field Suggestions	High
39	JWT	alg:none, Weak HMAC Key, RS256→HS256 Confusion	Critical
40	Clickjacking	Clickjacking — X-Frame-Options + CSP + DOM-based	Medium
41	TLS / HSTS	Weak TLS or missing HSTS	Medium
42	IDOR (Extra)	IDOR/BOLA with two identities (Victim vs Attacker vs Anonymous)	Critical
43	Business Logic	Business logic flaws — Cart/payment/price/voucher exploitation	Critical
44	Business Logic Anomaly	Business logic anomaly detection	Critical

Two Identities (14 types)

#	Vulnerability	Description	Severity
45	Access Control	IDOR/BOLA with two identities (Victim vs Attacker vs Anonymous)	Critical
46	403 Bypass	Access control bypass — Method Tampering • Header/Path tricks	High
47	JWT Bypass	alg:none, Weak HMAC, JKU Confusion • decode	Critical
48	GraphQL Introspection	Open introspection • Field Suggestions	High
49	NoSQL Operator	$ne / $gt in JSON body — auth bypass	Critical
50	Mass Assignment	BOPLA — privileged field injection (isAdmin, role)	High
51	Stored XSS (Poll)	Two-request confirmed stored XSS	High
52	DOM XSS Static	Source→Sink in JS — static code analysis	Info
53	Secret Live Validation	Key validation via provider API directly	Critical
54	Exposed VCS	.git/config, .env, .svn/entries — leaked files	High
55	Subdomain Takeover	CNAME to AWS, Azure, GCP, Github, Heroku + 15 services	High
56	CSRF (Poc)	CSRF confirmed via replays	High
57	Rate Limit	Brute-force exposure — no 429/503 across N requests	Medium
58	Clickjacking (Poc)	PoC + X-Frame-Options + CSP analysis	Medium

Turbo Modules — Burp-Suite Class (13 types)

#	Module	Description	Severity
59	Intruder	Wordlist-based fuzzing — Position Markers • Cluster Bomb • Statistical Anomalies	High
60	WebSocket XSS	XSS via WebSocket — payload reflection confirmation	Critical
61	WebSocket SQLi	SQL Injection via WebSocket	Critical
62	WebSocket SSTI	SSTI via WebSocket	High
63	WebSocket LFI	LFI via WebSocket	High
64	WebSocket NoSQL	NoSQL Injection via WebSocket	High
65	Request Smuggling	CL.TE / TE.CL / TE.TE — header conflict exploitation	Critical
66	Prototype Pollution	__proto__ / constructor.prototype — Server + Client	Critical
67	DOM XSS (Live)	Playwright browser — inject + confirm alert() fire	Critical
68	DOM XSS (Static)	Source→Sink — static DOM XSS analysis	Info
69	Sequencer	Token randomness analysis — Shannon Entropy • Position Bias	Info

OCR / Blind Extraction (5 types)

#	Vulnerability	Description	Severity
70	SSRF Preader (OOB)	X-Forwarded-For, True-Client-IP, Referer — Interactsh	Critical
71	SSRF (Param OOB)	Blind SSRF via parameters	Critical
72	CMDI Blind (OOB)	Blind OS Command Injection via curl/nslookup	Critical
73	LFI/SSRF OOB	Blind LFI/SSRF with Interactsh callback	High

Recon & Mining (3 types)

#	Type	Description	Severity
74	JS Endpoint Mining	Extract API endpoints from JS files — LinkFinder-style	Info
75	JS Secret Mining	Scan JS files for secrets and keys	Info
76	Path Discovery	Dirbuster-style — admin, .git, .env, API docs, backups	Info